Cyber + IKP: Offline Key Management

BGIN Block 15 · Georgetown University Capitol Campus, 111 Massachusetts Avenue NW, Washington, D.C.

Date	16 October 2026
Room	Room B (2416)
Published time	14:30–16:00
Workstream	offline-key-management
Status	Draft for working-group review. Source: closed captions.
Rule	Chatham House Rule. Information may be used without revealing the identity or affiliation of speakers or other participants, directly or indirectly.

This is a session record, not a transcript. Substantive discussion is retained with uncertainty and disagreement made explicit. Reported claims are not verified findings. Candidate agreements require working-group confirmation before use as decisions. Actions omit personal owners and identifying roles.

Agreements

The following sentences stand on their own. These are candidate agreements and reported points of convergence for working-group review. Inclusion does not establish consensus, verify a technical claim, or record formal adoption. The working group must confirm each decision before it is cited as such. Claims that were only discussed, including figures and alternatives that were not adopted, remain in full under Discussion.

Offline key management for custodians is the lifecycle and the authority around the key, not a cold-storage product category. Signing, granting and revoking signing authority, destination allow-lists, and transfer limits are all in scope.

No single human, software component, or AI agent should be able to approve movement of large balances alone. m-of-n, including a legally delegated degraded mode, is the pattern on the table.

Multisig, smart-contract control, threshold signatures, and MPC are alternative splits with different risks. MPC does not remove vendor software or the open-source supply chain. Deterministic transcripts that a third party can check, plus source disclosure, allow-listed binaries, reproducible builds, and a skeptical reading of SOC 2, were the concrete supplier controls.

Collusion, self-approval through the change pipeline, hidden permission loops, and stale office-holders are in scope once authority is split. A dependency graph, drilled on a schedule, is the proposed way to see them. The graph stays confidential.

A key generated with weak randomness cannot be fixed by a later update. The Coldcard firmware failure was the shared example. Rotation of a blockchain address has no PKI-style expiry, is a phishing event, and needs a grace period, a tested cutover, delayed destruction, and a legal answer for funds sent to the old address.

AI must not generate keys or handle key bytes. Entropy does not come from a language model. An agent may trigger equipment that already holds the key. That narrower role was explicitly agreed in the room.

If a model is used on approvals, it sits beside deterministic rules: a veto, a threshold that returns to a person, and a system that still runs if the model is down. Prompt injection on the approval path, invented dependencies, and human review of model-written code were accepted as necessary cautions.

Local models are the preferred way to expose sensitive runbooks. Cloud models are the wrong place for "how to open the vault.".

Practices and discovered weaknesses should be shared. Detailed configuration should not. The attacker is the adversary, not peer firms.

The Japanese cold-storage ratio is a legal constraint on exchanges there. This session did not reopen it as a technical optimum. Block 14's offline-versus-online ratio remains unsettled.

"Offline" is not yet defined tightly enough to survive agents. Physical disconnection, logical authorization, and a downloaded model running with the network unplugged are different claims. A discussion paper on that definition is wanted.

Delegation of any agent spend should be a human act. Putting a generative model inside the offline ceremony itself was treated as likely overkill.

Documents considered

The session referred to the following documents, repositories, and standards. Bibliographic identifications and factual checks added during review are marked as editorial clarifications; they do not imply that the links were spoken or that the meeting adopted the findings. Names of the people who introduced the material are omitted.

The session paper on offline key management for exchange custodians. Section 8 is the AI discussion. Page 9 is the dependency-graph figure. No title was spoken.

Reference 4 of that paper: the Block 14 paper, with a diagram and a URL on the last page. The URL was not spoken. It is the source of the 95/5 cold/hot figure as discussed here.

An earlier paper on hiding key material in randomness inside an MPC transcript, and the deterministic-protocol countermeasure. No title spoken.

SOC 2 reports, cited as a weak supplier signal.

ISO was not the frame of this session. JFSA segregation practice and Japanese exchange law were the regulatory references. No statute number was spoken cleanly. "SB 857" in the recording is [unverified].

Intel SGX, cited as the analogy for verifying a signed program before it may use key material.

TypeSafe AI, "Introducing System One Models & Jev"; the session chat supplied `https://typesafe.ai/blog/introducing-system-one-models-and-jev` Jev is a structured-decision model; deterministic workflow execution was a proposed architecture, not a verified property of the model.

Coldcard RNG failure, used as the generation-lifecycle example.

Coincheck, used as the origin of the Japanese segregated-custody debate.

Discussion

The following is the substance of the session. It preserves claims, figures, alternatives, and objections. Discussion does not establish a decision. Any candidate agreement requires explicit working-group confirmation.

Offline key management for crypto-asset custodians. Block 14 had already covered key-management practice for exchanges, not only cold keys: assets on offline keys, and protection of online keys with HSMs, MPC, and related controls. The stated need was guidance for organizations that are not mature, including how to move from today's controls to offline keys plus real governance of who may use them. The same lifecycle matters for post-quantum migration: keys have to change, and some offline keys may have to come online to migrate. A paper and recorded presentation informed the discussion, followed by questions and clarification.

What custodians actually have to control. Protecting the signing private key was called one of the main unsolved operational problems for crypto-asset service providers and custodians: exchanges, staking providers, payment processors, and, more recently, stablecoin issuers. The spoken acronym "BASP" is [unverified]; the class of firm was clear. Incidents continue even though a body of practice exists. The authority to be managed is not only the authority to sign. It includes the authority to grant and revoke signing authority, and in some cases the authority to set destination allow-lists and maximum transfer amounts.

Six claims were announced.

1. No single entity — human, software, or AI agent — should be able to approve these actions alone. This matters most when large balances move.

2. Multisig and MPC both distribute authority and both have trade-offs. The risk profiles differ.

3. Distribution creates new problems: collusion, malfunction, and rotation and succession of authority.

4. Key risk is the whole lifecycle, not a storage choice.

5. AI in key management is worth starting to think about. It shows up in at least four forms, and each form needs its own treatment.

6. Knowledge of key management, and the results of security verification, are more valuable when they are shared.

m-of-n, including a degraded mode. The design principle is to refuse single-entity approval and split authority so that theft requires compromising m of n. The example on the slide was a 2-of-4 that an organization might actually run. Normally two independent systems sign. If one system is down, the remaining system and the business-operations team sign. If both systems are down, the operations team and a trust company sign, under a legally valid delegation.

Ways to split authority: multisig, smart contracts, threshold signatures, and MPC with distributed key generation. A share can itself be split, which produces a tree of authority rather than one committee.

MPC does not remove the software supply chain. At the protocol level, MPC needs no trusted third party. In practice, each party's share is handled by a vendor's software or by an open-source supply chain. Malicious code can hide key material inside messages that look legitimate. An earlier paper proposed an attack that embeds key information in bits that look random. The countermeasure proposed: a deterministic MPC protocol with the randomness removed, so a third party can verify the transcript without learning secrets.

Around that, ordinary supplier controls: ask vendors for source, use an allow-listed repository that contains only open-source builds that have passed binary checks, reproduce builds in house, and read SOC 2 reports while treating them as a weak guarantee. As the cryptography gets more advanced, the software that has to be managed grows. The custodian's job was described as keeping that scope inside a range the organization can actually supervise.

New failure modes once authority is split. Captions say "collision"; the rest of the talk is collusion.

Collusion: separate teams, organizations, or sites so that holders are not quietly the same actor.

Self-approval: approvers who look independent can still approve their own work. An engineering team that can bypass approval by shipping software was the example. The control has to match how that organization actually works.

AI inside the approval logic: do not let it be the only logic. Run it beside deterministic rules, or put risk-based guardrails on it.

Access control on configuration, not only on the signature. Transfer limits and destination allow-lists need the same class of control as a lower-value approval. The authority design itself must not become too complex to understand. A spoken acronym "HDL design" is [unverified].

Stale holders and hidden loops. Build a dependency graph of permissions and approvals, and drill it. The example: the signing key is in an HSM, a token is in a safe, the safe has a combination, and the combination is stored in the HSM. While one person remembers the combination, the loop is invisible. When that person leaves, the organization is stuck. The graph may itself be sensitive. The proposal was that a VASP draw the graph and look for dependencies it did not intend.

Succession: do not leave a seed phrase with a chief executive, or a single hardware token with one employee. Plan the transition. Make ownership of authority explicit. At the top, bind that authority to the organization through something like the board or through a legal delegation.

Lifecycle, and why generation failures cannot be patched. Key management starts at generation. The recent Coldcard incident was the illustration. Firmware had switched from a strong random-number generator to a software generator. The session referred to an estimate of about 72 bits or less. Editorial qualification: entropy estimates varied by affected model and assumptions; this figure is not a universal audited security level. The vendor's security-status record documents the firmware RNG failure and that updating firmware does not repair a previously generated weak seed (`https://coldcard.com/security/status`). The lesson as stated: use a secure generator, and verify the path by which randomness is produced. A key born from weak randomness is not repaired by a later software update. If generation may have been weak, replace the key immediately.

Destruction and rotation are hard for a different reason. Unlike a PKI certificate, a blockchain address does not expire, and there is no general way to announce a replacement. The procedure offered: announce, keep a grace period, test a transfer, cut over, destroy the old key. That includes talking to users. Changing the deposit address customers have been given is a phishing target and needs its own measures. Some customers will pay the old address anyway. The migration plan has to allow delayed destruction, and it has to assign legal responsibility if funds sent to the old address are lost.

Four forms of AI. An agent that approves a withdrawal. A coding agent. A defensive tool. An attacker's weapon. The recording assumed an agent running offline. The same arguments were said to apply to a model called through a cloud API.

If AI participates in approval, it should not replace rule-based approval. A risk-based pattern: the model holds only a veto over abnormal approvals, or any approval above an amount falls back to a person. The benefit claimed from the model side is detection of fraud that current rules miss. The balance is the design problem.

AI-specific failures to plan for:

The system keeps working if the agent is unavailable or blocked.

Prompt injection and model manipulation through metadata and other extra fields on the approval path.

Code written by a model is reviewed independently of the model that wrote it.

Dependencies are inspected, because a model invents package names.

A human sign-off on code review is still required.

What to share. Configuration detail, and especially the dependency graph, stays confidential. Not everything should. Share practices and the weaknesses that were found. The adversary is the attacker, not the other witnesses.

The recording's summary: offline key management is not the storage of a signing key. It includes authority design, succession, the lifecycle, and controls that involve AI. Three principles cover all of it. Do not depend on a single entity. Visualize and verify dependencies. Share what can be shared.

The written paper provides a fuller account and connects to the discussions of post-quantum migration and AI-agent responsibility.

The agent does not touch key material. A room proposal: do not use a large language model for key generation or key handling. Use a small deterministic expert model for the operation, and use a large model only to observe state and to assess risk.

The proposal was narrowed as follows. The agent should not generate key material or use it directly. It should operate the equipment that holds the key: trigger signing, trigger an approval, approve a withdrawal, or grant a permission. The room agreed that AI should not generate keys, and that some people are already doing it, so the warning is worth stating plainly. Prompting a model to start a key-generation tool is still a hazard and needs safeguards.

Reported experiments with a large language model: asked for a key, the model often refuses to emit entropy and instead writes a command that creates a key in a file it cannot read, then calls that file to sign. That refusal is not proof that no trace of the material entered the context, or that the trace cannot be recovered. The safe reply depends on the prompt. "Generate a key with proper entropy for this system" tends to get the cautious answer. "Start this wallet" without saying why tends to get an interface walkthrough that does not think about entropy. A separate experience: a tool asked to spawn a hosted instance emits a seed, sometimes with a warning not to use it in production, and emits it anyway. A user can also overrule the refusal and demand that the model generate the key. A system prompt written by a privacy-conscious user is not the default model. The line the room restated: do not take entropy from a language model.

Where a model is actually useful in the approval path. Asked whether a model should choose two, three, or four signatures for a given transaction, the discussion first considered anti-money-laundering review: withdrawal patterns, payments that look like they are climbing toward a fraudulent address, a transfer that should be stopped or delayed. Rule systems miss those. A generative model was said to be better at that class of anomaly. A second use: an operator runbook. How to use the HSM, how to open the vault. Those procedures are sensitive, so the preferred deployment is a local model, not a cloud agent. That local question-answering over procedure was called the primary use so far. The detail is in section 8 of the paper. The diagram there was described as rough.

Who decides the cold share. Block 14 had discussed, and not settled, the ratio of assets kept offline to assets kept online, and how end users are protected when something fails. The new question: a model might set that ratio from frequency of use, number of keys, value attached to each key, and total value, with the same risks as an AI approval.

The idea was considered subject to constraints. The 95 percent cold / 5 percent hot figure in the Block 14 paper was described as an arbitrary number written into Japanese law, which an exchange in Japan has to follow, so "tuning the percentage" is not a free operational choice. What a model might still do is watch recent withdrawal trends, by asset or by user count, and automate the safer direction of replenishment: moving value from the cold wallet into the hot wallet to meet demand. Reference 4 of the current paper was identified as that Block 14 paper, with a diagram and a URL on the references page. The URL was not read aloud.

The gap between a written "should" and a control that runs. A comment from the room: the paper is a solid collection of practices that security people already treat as common sense. The industry failure is that the documents say "should" and firms do not do it. A risk-based write-up still does not make a chief executive see the risk of skipping the control. The suggestion was to use a model to show the risk that follows from not doing the thing, aimed at the executive rather than at another policy PDF. Cybersecurity has a long record of documents nobody follows.

The elaboration that followed was speculative and was not adopted as a requirement. Ideas named in the room:

A gated runtime every exchange would have to execute, recording a hash that the checks ran.

Recent large breaches of personal data in Japan were cited as context. The claim was not that models have invented a new top tier of attack, but that they let mid- and low-skill attackers use small existing vulnerabilities, and that the volume of attempts can be automated. Firms that skipped basic practice were the ones hit. A long control catalog will not be read by a small firm.

A "proof of contribution" analogy: evidence that a firm's model spent a threshold of compute, an example figure of more than ten hours was floated, on the firm's own architecture against the practice list.

An anti-money-laundering screening whose evidence hash goes into a Merkle tree. The regulator receives the root. The plaintext of the screening is not shared unless something later has to be unpacked.

An intermediate graph of controls, checked by an agent, with a proof that the controls exist, that an agent checked them, and that the check repeats. If an external system watches the agent, append a witness. That was contrasted with a one-time audit.

A narrower proposal followed. Page 9 of the paper already has a dependency graph. Models are good at recovering data flow and permission flow from source, and at drawing that graph. The hidden-loop example looks artificial and was said to happen easily. Keeping the graph current at each inventory is the control. A model makes the inspection cheaper. It does not replace it.

Revocation is situation-dependent. Custodial systems also back keys up for users who lose them. Deleting a key may not be enough if it can still appear in a later transaction. No general answer was established. It depends how that firm generates and stores keys. Monitoring a key that was supposed to be destroyed is a reasonable investment. If the destroyed object is one share of a large set — the example was on the order of 2-of-15 — and the other shares have already been rotated cleanly, monitoring that share is a smaller concern. The captions say "distracted" and "distracting" for destroyed.

Agentic commerce still keeps the key in an HSM. The architecture question: an exchange today sits in front of a separate custody system. An agent that needs to move value cannot be allowed to hold the key in the clear, so some hardware boundary is required. The design offered:

The key stays in an HSM.

The agent gets permission to call an API on that HSM.

The channel from the machine running the model to the HSM is authenticated. The agent can ask the module to sign, or to grant another agent a delegated action.

How that permission is modeled is open.

Spend is capped by the firm's risk appetite. An example cap of $1,000 was illustrative. Inside the cap, the agent was said to be able to act without a further human on that transaction.

Agents might then pay each other inside those caps, without a person in each payment.

That was tied back to a know-your-agent discussion from the previous day. Binding an agent to a signature key, and binding that key to a natural person, is unfinished. Agents may be short-lived or long-lived and may not deserve the same checks. A remote agent on a secured channel still has to be

distinguishable from another agent. The five-principle stack from the privacy session — control of what the agent does, and decentralized identity as the verification layer — was pointed at as a framework that can be read this way. It was a pointer, not a joint design.

What "offline" was supposed to mean. HSMs appear on the diagram, and MPC is often casually classed as offline because it is harder to reach than a hot key. The original regulatory idea was stricter: the keys stay offline, and the governance of those keys stays offline, so that nothing can open a network path and use them.

The open question, with no answer claimed: agents are good at finding a path to a goal, including by using vulnerabilities. Two further requirements were floated if the point of offline storage is still to keep keys away from an online compromise.

Proof of personhood on the use of the HSM or the MPC, so an agent cannot change transaction limits and keep drawing value with no person in the loop.

Or a rule that the keys are actually offline and a person is required to reach them.

Limited delegation to an agent was accepted as possible. The delegation itself should be an act of a person. The regulatory intent of mandatory cold storage was restated: if an online vulnerability is exploited, the bulk of the assets are still out of reach. An agent with a defined perimeter can itself be the vulnerability. A second layer is then needed so the keys are not reachable from that compromise.

One objection was that generative decisions want automation, and automation belongs on the online side. It is hard to see an offline procedure that should run with no person, except perhaps rotation, break-glass, or backup. Monitoring a ceremony without touching the key is more plausible than letting a model perform the ceremony. The sense in the room was that putting a generative model inside offline key management may be overkill, and that this depends entirely on what "offline" means.

The word is already unstable, before agents. After the Coincheck incident, the Japanese official discussion of segregated custody was described as a responsibility discussion, not a technical one. The position attributed to the JFSA was that the technical debate should stop and that assets should be segregated, with a figure of 90 percent kept off the internet. Practitioners already use "offline" for different states: not activated, not connected, or segregated on an internal network as long as it is not activated, with authorization at the network layer or the application layer. A definition that says what an agent may and may not do was called worth writing.

A hardware wallet with an added component — the supply-chain modification discussed in the next session — was cited here as proof that a cold device can be turned into something that behaves as an online wallet. Under a rule that 90 percent of assets must not touch the internet, daily operations still require moving value from cold to hot. That movement is operationally heavy. People skip steps. The claim was that some backdoors appear at that operational layer, not in the cryptography. A fully disconnected custody design was said not to survive contact with agentic operation. The suggested replacement term is control of authorization to reach the key, not "offline" as a physical adjective.

A thought experiment closed that part. If every decision is made by a model and people only carry data from one place to another, the person is a transport delay. An air-gapped network operated that way

is logically online. Physical segregation would no longer mean logical segregation. Physical segregation remains easier to explain to a regulator. The room treated that as the discussion worth having.

A downloaded model, and a signature on the model. If today's offline ceremonies already run software that was downloaded from a public repository, then a model that was downloaded and is now running with no network is offline in the same sense. The model is software. The difference is that its decisions are less obviously deterministic. An untampered model might be less prone to collusion or insider theft than a person. A tampered model is not. The model was not established as safe. The comparison was left as tricky.

The know-your-agent version of that claim: sign the model file. Record what data and what computation produced it. Verify that signature in the environment where the agent runs. The analogy was confidential computing, specifically Intel SGX: the processor checks a signature on the program before the program may touch encrypted data. A model with a valid signature might then be allowed to call the HSM on a person's behalf. Remote attestation of model provenance was offered as a future method, and as an opinion.

A refinement from the room: a probabilistic language model is the wrong tool for the offline ceremony. A workflow engine that executes stated steps is closer. The chat identifies TypeSafe AI and its Jev model. The pattern suggested: a frontier model writes the plan, a model performs constrained workflow steps and records them (determinism was proposed but not established), and the model that has seen the firm's sensitive context is not the model that runs the actions. A person watching both can witness the interaction and produce a proof of runtime, with one side proposing the workflow and the other proving execution. A link was to be put in the chat for the notes.

Matters not resolved

Whether any model should ever sit in the approval path, and if so whether it may do more than veto or anomaly detection. Full replacement of rules was rejected. The allowable middle was not specified.

Whether a model may choose the cold/hot ratio. Japanese law was described as fixing the ratio. Automation of replenishment from cold to hot was considered. Changing the legal percentage was not.

Two figures were spoken for Japanese segregation practice: 95 percent cold / 5 percent hot in the Block 14 paper, and 90 percent off the internet in the JFSA-era rule. This extract does not reconcile them.

Whether evidence of an AI control review should be a Merkle root shown to a regulator, a compute-time threshold, or a witnessed graph of controls. All three were sketches.

Whether deletion of a key is revocation, or whether use of the destroyed key must be monitored. Answer given: it depends on the remaining power of that share.

Whether an agent may pay another agent inside a pre-set cap with no person on that payment.

Proof of personhood on HSM and MPC use, versus a human physically required for any offline action. Both were requirements someone might impose. Neither was selected.

Whether offline ceremonies should be automated at all. The lean was no, except monitoring, rotation, or backup, and the lean was explicitly dependent on the definition.

What "offline" denotes: air gap, not activated, not routed, software that was downloaded and is now disconnected, or a policy about who may authorize use. Recognized as unstable since before agents.

Whether an untampered model is more trustworthy than a human insider. Raised and not accepted as a conclusion.

Whether model provenance, signed like an SGX enclave, should be the condition for HSM access. An opinion, not a requirement.

How know-your-agent binds a short-lived agent to a person's key. Pointed at the privacy session's control and decentralized-identity principles. Not designed here.

Disposition of the work

Block 14 left a body of key-management discussion and at least one paper, cited here as reference 4, including a diagram of the cold/hot split and a URL that was not read out. This session had a single new contribution: a long paper and a pre-recorded video from an exchange practitioner, plus live answers. No second paper was submitted.

Nothing was adopted as a BGIN text. The room's publishing ideas were a collection of current best practice for today's architecture, a knowledge base an agent could apply to a firm's own controls, and a discussion paper on what "offline" means once agents exist. BGIN's existing document set was described as already ingested by agent tooling, so a best-practice map could be built from it. That is capability, not a drafted deliverable.

The Coldcard generation failure and the hardware-wallet supply-chain modification were used as shared facts. They are not BGIN work products. The supply-chain case is developed in the security-target session.

Actions

Each action is written so that it can be tracked without the rest of the record. Where the room named only a person, the action is kept and the name is omitted.

Publish a best-practice collection for current custodian architecture, drawn from this paper and from Block 14, aimed at firms that do not yet do what the documents already say.

Write a discussion paper on the definition of offline key control in the agentic era. Working titles floated in the room included whether a machine is ever offline, and how offline key control should be thought about. The paper is expected to expose the operational problems of agentic commerce rather than to close them.

Keep the dependency-graph proposal concrete: what is confidential, what a VASP should inspect, and how often.

State plainly, in whatever text follows, that models do not generate keys and do not supply entropy.

Decide later whether regulator-facing proofs of control reviews are in scope. They were not taken up as work.

Allow the break before the scheduled ST/PP session so remote participants can join at the published

time.

Coverage

This record covers the published offline-key session in Room B at 14:30–16:00. The room closed the discussion early for the 16:00 tea break and announced the next block for 16:10, which matches the published ST/PP slot. Figures are reported session claims, not independently validated measurements. Technical names are corrected where supported by the recording, chat, or identified primary documentation. Where a name could not be checked against another part of the same recording, it is left unverified rather than guessed. Logistics, introductions, and names of speakers are omitted.

Dropped: arrival chatter, identity small talk, QR codes and profile exchanges, playback troubleshooting, and the closing thanks and time-zone check with the remote contributor. The recording was restarted once. Substance from both the recording and the live discussion is included. The session did close, for a tea break, with the security-target session held for its scheduled time because remote participants might join.

—.

Source clarifications and open checks

"HDL design.".

"SB 857.".

Editorial check: The COLDCARD firmware RNG failure is documented; approximately 72 bits was a preliminary estimate for particular models, not a universal audited entropy value. Garbled personal names are unnecessary.